

VULNERABILITY ASSESSMENT REPORT

Task 1 • Cyber Security Internship

Prepared by

Subhan Shaikh

Future Interns – Cyber Security

Assessment Type: Passive / Read-Only

September 2026

Assessment

Passive, read-only review of permitted public test environments. The work focused on observable security configuration and information disclosure.

Tools Used

Nmap • ZAP 2.17.0 • Microsoft Edge Developer Tools

Key Observations

Cookie security attributes, missing security headers, and server technology information were observed. Findings were treated as configuration/hardening issues.

Overall Assessment

LOW RISK
No exploitation, brute force, login bypass, DoS, or harmful testing was performed.

1. Assessment Objective

The objective of this assessment was to identify common observable web security weaknesses and configuration issues.

The assessment aimed to:

- Identify publicly observable security weaknesses.
- Review exposed services and basic port status.
- Examine HTTP response security headers.
- Review cookie security attributes.
- Identify server technology information disclosed by response headers.
- Classify observations by risk.
- Provide practical remediation recommendations.

The assessment followed a passive / read-only methodology.

2. Scope & Ethical Considerations

4

In Scope

Public-facing pages
Passive scanning
HTTP response-header inspection
Cookie attribute inspection
Basic service / port observation
Browser Developer Tools analysis

Out of Scope

Login bypass
Brute-force attacks
Exploitation
SQL injection payloads
XSS payloads
Denial-of-service testing
Destructive or unauthorized testing

Targets

Nmap: testphp.vulnweb.com

ZAP / Browser: testasp.vulnweb.com

Results are kept separated by target.

3. Assessment Methodology

5

01 • Nmap

Basic service and port observation was performed against the permitted test target.

02 • ZAP Passive

ZAP 2.17.0 observed traffic generated during normal public-page browsing. No active scan was performed.

03 • Developer Tools

Edge DevTools Network and Cookies panels were used to inspect response headers and cookie attributes.

Evidence Handling

Screenshots and Nmap output were retained in the project evidence/screenshot folders.

4. Nmap Assessment

6

Target

testphp.vulnweb.com

Observed Result

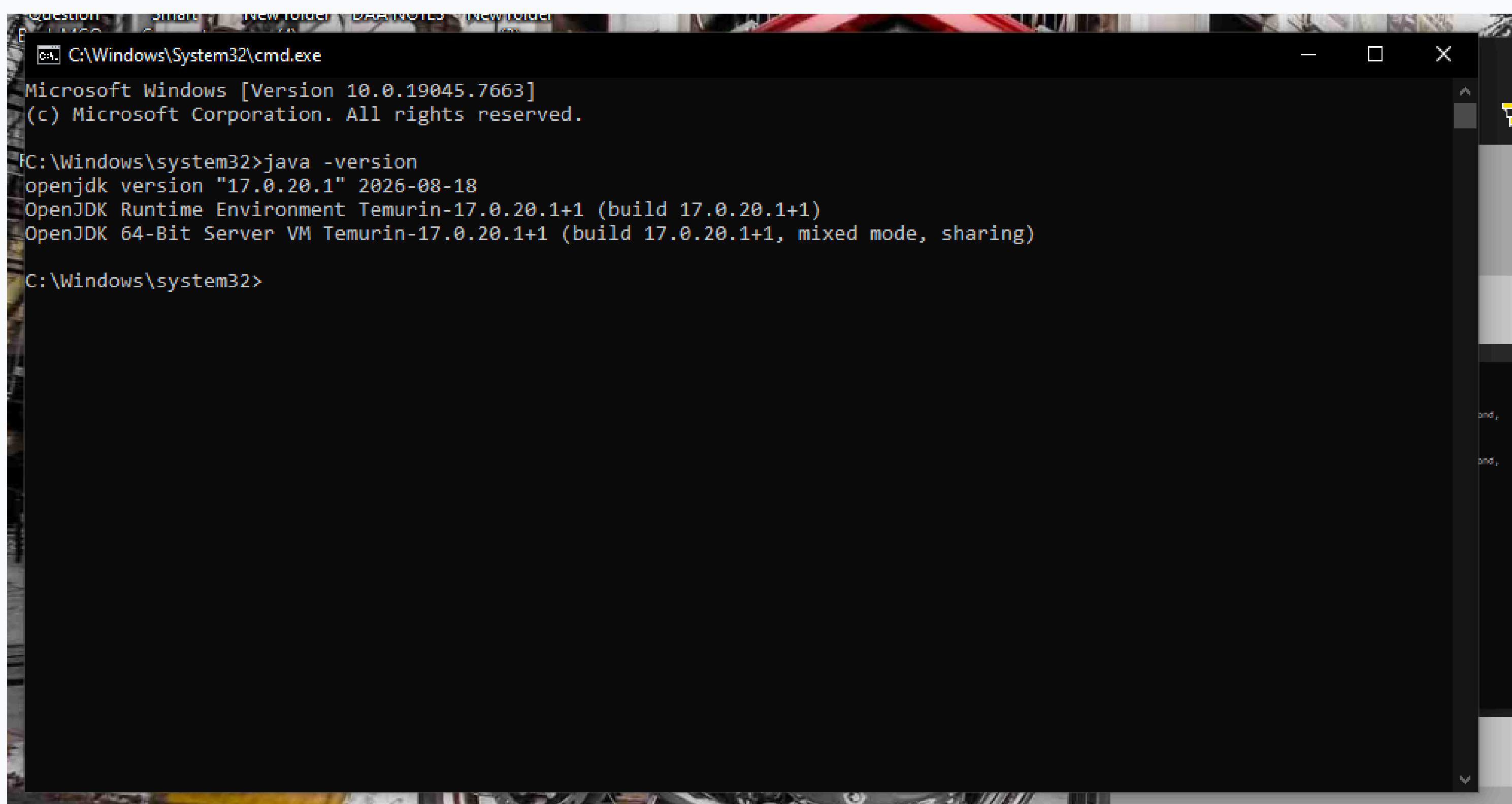
Host was up. The scan reported 1000 TCP ports as filtered / no-response. This is an observation, not proof of a vulnerability.

Command

```
nmap -sV testphp.vulnweb.com -oN evidence\nmap-results.txt
```

Risk

Informational / Low. No exploitable service was confirmed by this conservative scan.



5. ZAP Passive Assessment

Target

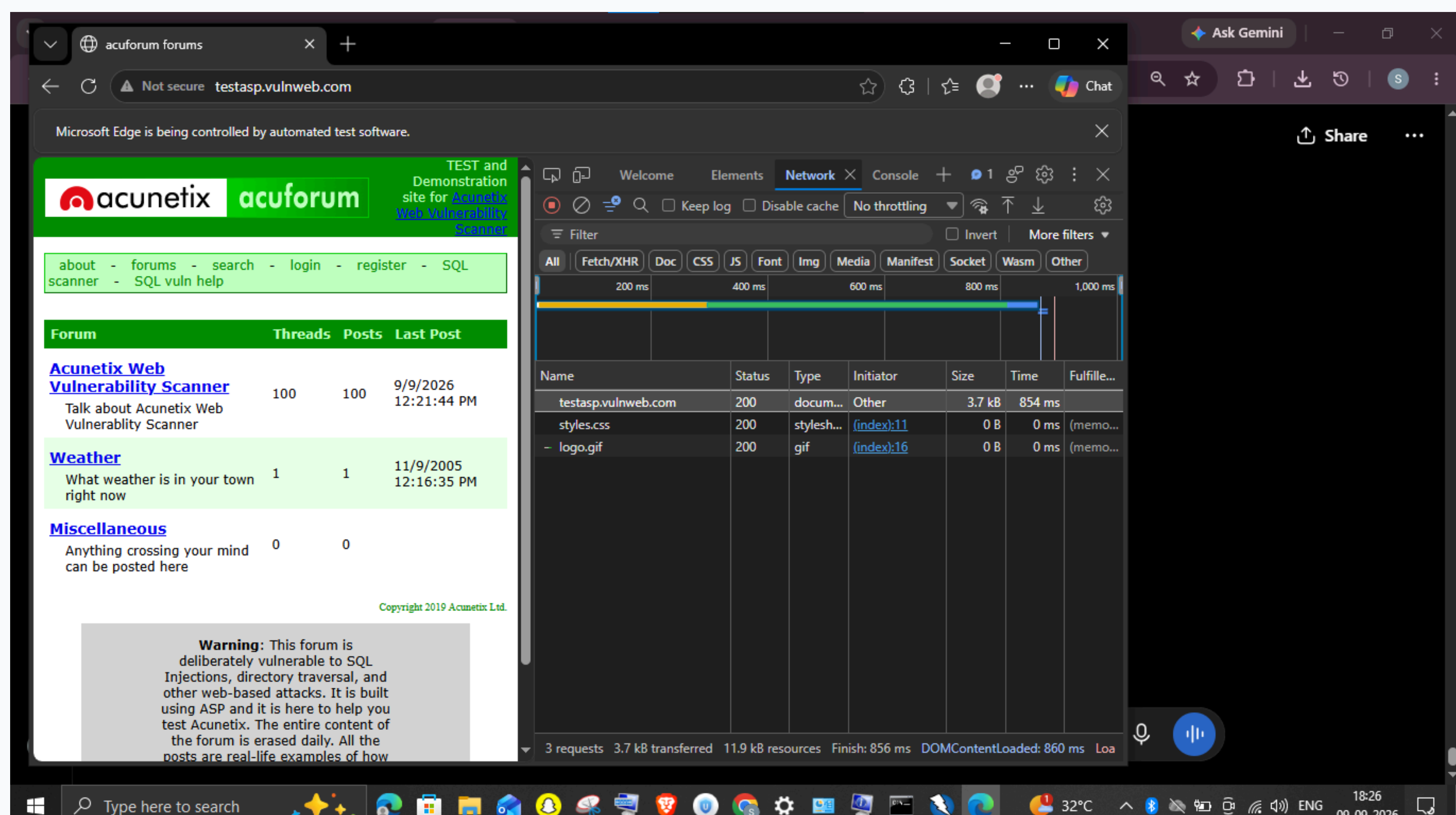
testasp.vulnweb.com

Mode

ZAP 2.17.0 • Passive / Read-Only
Normal public-page navigation only.

Observed Alerts

Cookie No HttpOnly Flag
Cookie without SameSite Attribute
Cookie with SameSite Attribute None
Server / X-Powered-By information disclosure
Strict-Transport-Security header not set
X-Content-Type-Options header missing



5.1 Finding — Cookie Security Attributes

Cookie without HttpOnly

ZAP reported a session-related cookie without the HttpOnly flag. Without HttpOnly, browser JavaScript may be able to access the cookie.

Cookie without SameSite

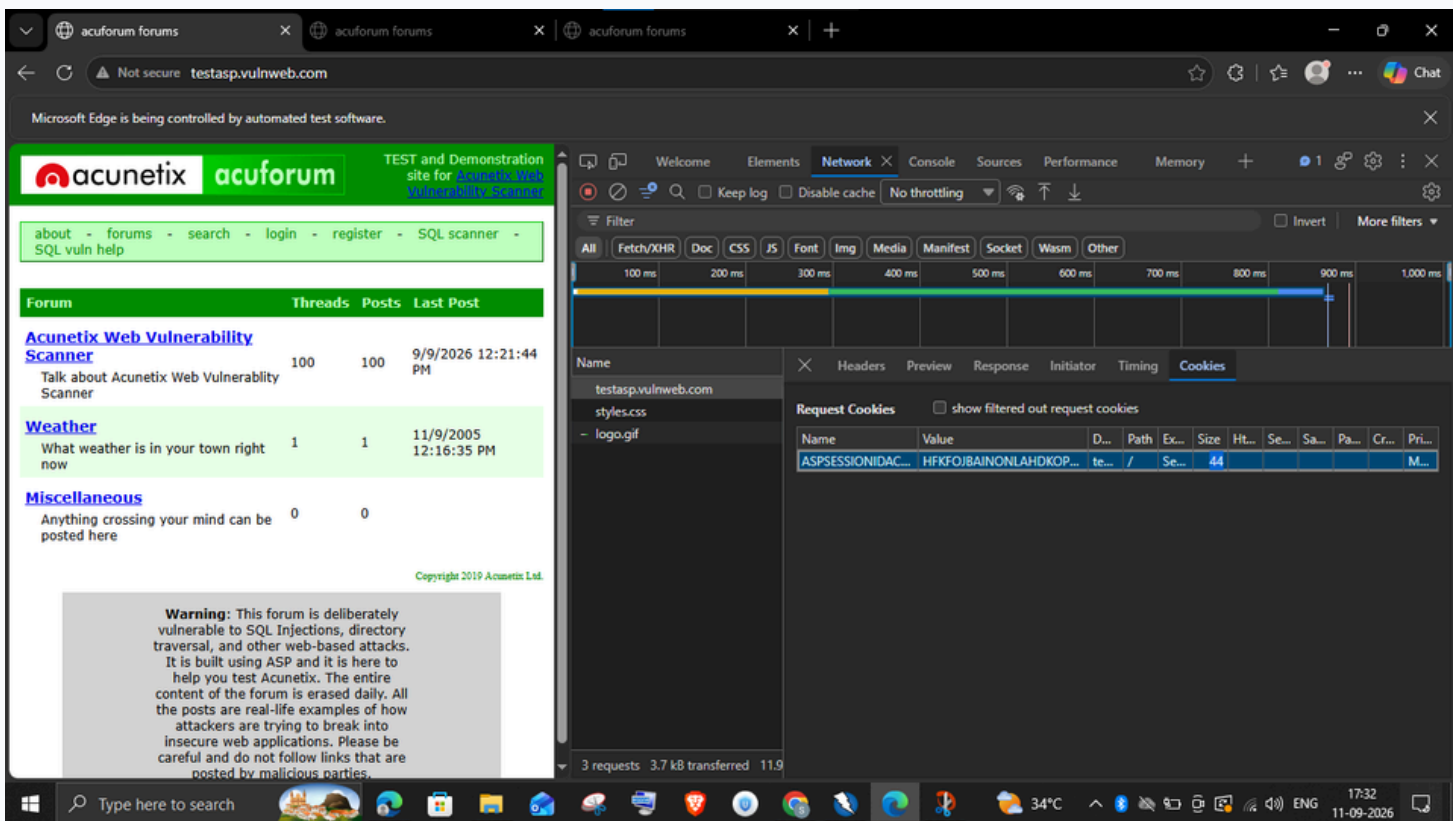
ZAP reported a cookie without the SameSite attribute. This reduces explicit control over cross-site cookie behavior.

SameSite=None

ZAP also observed a cookie using SameSite=None. Such use should be intentional and appropriate for the application's cross-site requirements.

Risk & Remediation

Risk: LOW
Use HttpOnly for sensitive session cookies and apply Secure and an appropriate SameSite policy where supported by the application's requirements.



5.2 Finding — Server Technology Disclosure

Observed Headers

Server: Microsoft-IIS/8.5
X-Powered-By: ASP.NET

Why It Matters

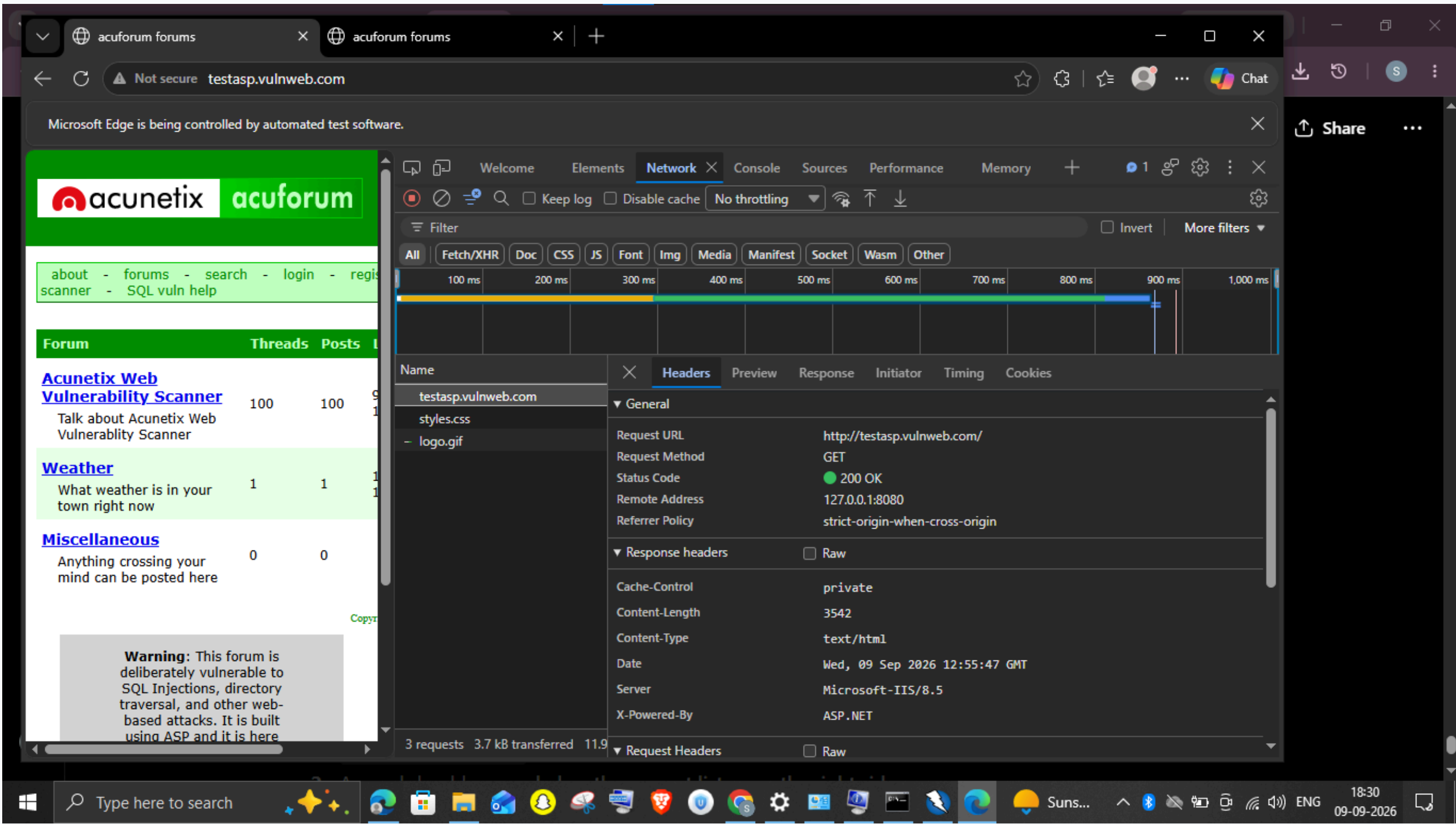
These headers disclose implementation details that can help reconnaissance and technology identification.

Risk

LOW — information disclosure / hardening issue. The observation alone does not demonstrate compromise.

Recommendation

Minimize unnecessary Server version disclosure and remove or suppress X-Powered-By where practical.



5.3 Finding — Missing Security Headers

ZAP Observations

Strict-Transport-Security header not set
X-Content-Type-Options header missing

Why It Matters

Security headers provide additional browser-side protections and reduce exposure to certain classes of web attacks.

Risk

LOW — configuration / security-hardening issue.

Recommendation

Where applicable, configure HSTS and X-Content-Type-Options: nosniff. Review CSP and other modern security headers according to application requirements.

6. Browser Developer Tools Evidence

Network Request

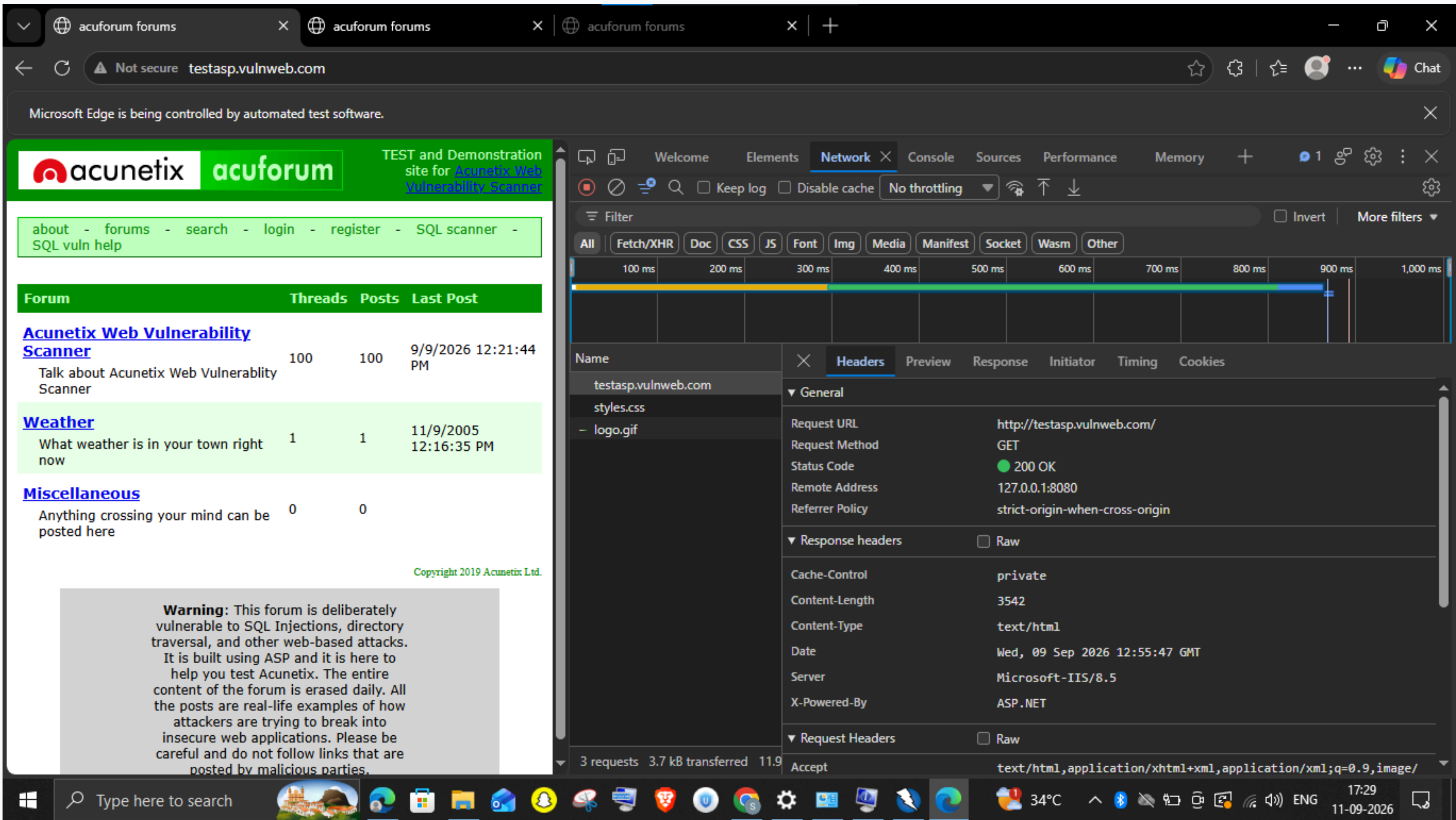
Request URL: http://testasp.vulnweb.com/
Method: GET
Status: 200 OK

Response Headers

Server: Microsoft-IIS/8.5
X-Powered-By: ASP.NET

Cookie Panel

An ASPSESSIONID... cookie was visible in the Cookies panel. This supports the cookie-related passive observations.



7. Risk Summary

12

LOW — Cookie without HttpOnly

Sensitive cookie should use HttpOnly where appropriate.

LOW — Cookie without SameSite

Apply an appropriate SameSite policy based on application requirements.

LOW — SameSite=None observed

Review whether cross-site cookie behavior is necessary and intentional.

LOW — Technology disclosure

Minimize unnecessary Server and X-Powered-By information.

LOW — Security headers

Review HSTS and X-Content-Type-Options and other modern headers.

Overall

LOW RISK

The assessment identified hardening opportunities; no active exploitation was performed or confirmed.

8. Recommended Remediation

13

Priority 1 • Cookies

Use HttpOnly for sensitive session cookies. Apply Secure and an appropriate SameSite policy.

Priority 2 • Security Headers

Review and configure Strict-Transport-Security and X-Content-Type-Options. Evaluate CSP where appropriate.

Priority 3 • Information Disclosure

Reduce unnecessary Server version and X-Powered-By disclosure.

Priority 4 • Ongoing Review

Perform regular security configuration reviews and authorized vulnerability assessments.

9. Conclusion

14

The passive vulnerability assessment identified several security-hardening opportunities in the permitted test environment.

The main observations involved cookie security attributes, missing security headers, and server technology disclosure.

The findings were classified primarily as LOW risk. They represent configuration and information-disclosure concerns rather than confirmed compromise.

The assessment was conducted responsibly using passive techniques without exploitation, brute-force activity, login bypass, denial-of-service testing, or other harmful actions.

Implementing the recommended controls would improve the application's overall security posture and reduce unnecessary information exposure.

Evidence Folder

FUTURE_CS_01\evidence\n
Nmap output: nmap-results.txt

Screenshots Folder

FUTURE_CS_01\screenshots\n
Nmap result • ZAP alerts • DevTools Network • Cookies

Tools

Nmap
ZAP 2.17.0
Microsoft Edge Developer Tools

Project Note

Keep Nmap observations under
testphp.vulnweb.com and ZAP/DevTools
observations under testasp.vulnweb.com.

Submission Package

Recommended public repository structure:
FUTURE_CS_01/
├─ README.md
├─ Vulnerability_Assessment_Report.pdf
├─ evidence/
└─ screenshots/